# Asset Tracker – Security Summary

Oct 21, 2026

## Overview

Asset Tracker records who holds each piece of equipment, with sign-in protection, role-based access and a tamper-resistant audit trail built in. It is a web app for tracking equipment handed to people: laptops, devices, tools and kits. Each customer runs their own separate copy, on their own servers or hosted for them, so no data is shared between customers.

The controls below are on by default unless marked optional. They were designed with SOC 2 controls in mind; Asset Tracker is not SOC 2 certified.

## Sign-in and identity

| Control | How it works |
|---|---|
| Single sign-on | Optional. Sign in with your company's identity provider through the OpenID Connect standard, supported by Microsoft Entra ID, Google Workspace, Okta and others. Once switched on, everyone signs in this way except one emergency admin account. New users get no permissions until an admin assigns a role. |
| Two-factor authentication | One admin switch makes an authenticator-app code mandatory for every user. Users enrol at their first sign-in and receive one-time recovery codes. Admins can reset a user's 2FA. |
| Passwords | 8 to 128 characters, stored only as bcrypt hashes. Non-admin passwords expire after 90 days, with an email reminder 3 days before. |
| Password resets | Reset links expire after 5 days. A reset by an admin signs the user out everywhere. |
| Brute-force protection | An account locks after 5 failed sign-ins and admins are alerted. Sign-in attempts are rate-limited per IP address. |

| Control | How it works |
| --- | --- |
| Sessions | Secure, HTTP-only, same-site cookies. Sessions end after 30 minutes idle or 8 hours in total. |
| Account status | Admins can deactivate a user, which ends all of their sessions at once. |

Password expiry, reset-link and session lengths can be adjusted per installation.

## Access control

Every request is checked on the server against the user's role, not just hidden in the interface.

- **Roles you define:** each role is a set of permissions per area (items, assignments, users, reports and so on) and per action (view, create, edit, delete).
- **Least privilege by default:** new single-sign-on users start with no permissions until an admin grants them a role.
- **Approvals:** items can be set to need an approver before they are handed out, and returns are confirmed by an admin.
- **Emergency access:** when single sign-on is on, only one local admin account can still sign in with a password, and it always needs 2FA.

## Audit and monitoring

Every important action is recorded in an audit log that the app never edits or deletes.

- **Audit log:** sign-ins and failures, lockouts, 2FA changes, password resets, role and permission changes, and every item, assignment and return. Each entry has the user, time and IP address. Admins can search and export it.
- **Independent copy (optional):** every audit entry can also be sent to your own log system or SIEM, so the trail survives even if the database is compromised.
- **Security alerts:** admins are notified of account lockouts, repeated 2FA failures, permission changes and spikes in server errors.
- **Error monitoring (optional):** errors can be reported to Sentry, with personal data removed first. It is off until an admin switches it on.
- **Item history:** each item keeps a full history of who held it, who handed it out, and the condition it came back in.

# Data protection

Data is encrypted in transit and at rest, and the app collects only what it needs to track equipment: names, work emails, roles and item records.

| Area | How it is protected |
|---|---|
| In transit | HTTPS everywhere, with HSTS, a Content Security Policy and anti-framing headers. Database connections require TLS. |
| At rest | The recommended database (MongoDB Atlas) encrypts storage with AES-256. 2FA secrets are also encrypted separately with AES-256-GCM. |
| Item photos | Stored in a private bucket and shown only through short-lived signed links. |
| Phone notifications | Contain no item or people names, and are encrypted end to end to the device. |
| Backups | Backups come from the database service: daily automatic snapshots on paid MongoDB Atlas plans (Flex and above), with a documented restore procedure. Self-hosted installations use their own backup tools. |
| Retention | Read notifications are deleted after 90 days; expired reset links, unused phone registrations and expired sign-in rate-limit records (which hold IP addresses) are removed automatically, on every hosting setup. |
| Leaving users | Deactivation removes all access at once. Records are kept so the audit trail stays complete. When someone asks to be erased, an admin can then anonymise the deactivated account: name and email become a placeholder everywhere, sign-in data is deleted, and IP addresses can be removed from their audit entries. Anonymisation is permanent and kept separate from deactivation, which can be undone. |

# Hosting, development and compliance

**Hosting.** Choose between running Asset Tracker on your own servers (Docker), which keeps all data inside your network, or having it hosted for you. The standard hosted setup uses these services:

| Service | Used for |
|---|---|
| Cloud hosting provider (named on request) | Running the application |
| MongoDB Atlas | Database |
| Cloudflare R2 | Item photos |
| SendGrid | Sign-up, reset and notification emails |
| Sentry (optional) | Error monitoring |
| Browser push services (optional) | Phone and desktop notifications |

**Development.** Every code change runs automated tests, secret scanning and code security scanning. Dependency updates are tracked automatically. A written incident response plan, change management policy and data retention policy are in place.

**Compliance.** Asset Tracker is built with SOC 2 controls in mind but is not SOC 2 certified. We are happy to answer security questionnaires.

**Contact.** For security questions or to report a vulnerability, email daliaalymohamed@gmail.com.